Subject: Suspicious Activity Linked to IP Addresses Associated with Uganda Telecom Ltd

To: Uganda Telecommunications Corporation Limited (UTCL)

Telephone House – Kampala , Plot 2A-4A Speke Road

Date: December 13th , 2024
Prepared by: William Moru
Title: ***Cybersecurity Engineer |Certified Ethical Hacker | Senior Software Tester (app Security)***

Dear *Uganda Telecommunications Corporation Limited (UTCL)*

I hope this message finds you well. My name is William Moru, and I am a cybersecurity engineer and a Certified Ethical Hacker who conducts routine Cybersecurity research and threat intelligence analysis on publicly available assets on the internet as part of my professional research. During a recent assessment, I identified critical security concerns associated with multiple IP addresses linked to Uganda Telecom Ltd, but zeroed my investigation to this IP address `196.0.111.194.` although other ip addresses identified also had indicators of malicious activities.

This report provides an in-depth analysis of the findings related to IP address `196.0.111.194`, flagged for malicious activities by multiple threat intelligence platforms. The analysis suggests and highlights the server association with phishing campaigns, malware distribution, and broader malicious operations such as DDoS attacks and botnet activities. The report also outlines the implications of these findings and provides actionable recommendations for mitigating the identified risks.

Key Findings

IP Metadata:

- **ASN:** AS 21491 (Uganda Telecom).
- **IP address** `196.0.111.194`
- **Geo Location:** Uganda.
- **SSL Certificate:** Self-signed, a typical characteristic of malicious entities attempting to bypass certificate authority validation.
- **Last Analysis Date:** 2 days prior to this report**.**

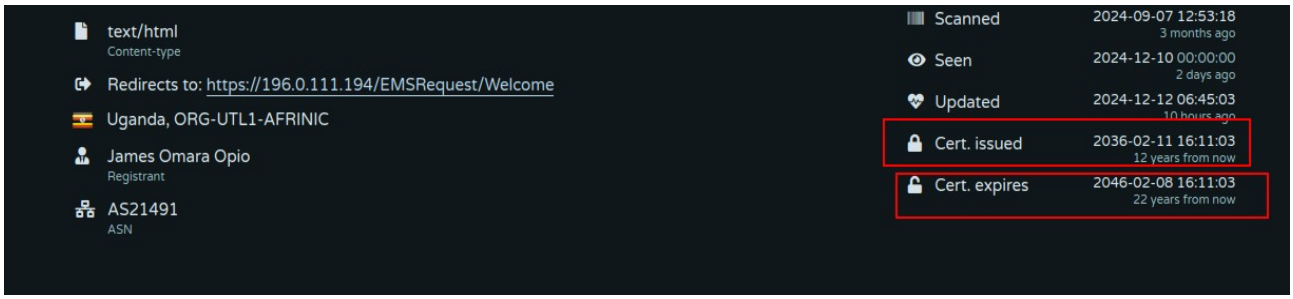
Analysis Findings

1. Critical Risks Identified

For IP **196.0.111.194**, key findings include:

- **Self-Signed SSL Certificate**:
    - The server is using a self-signed SSL certificate, which is not trusted by major browsers or systems.
    - Such certificates are prone to exploitation, including potential man-in-the-middle (MITM) attacks.
- **Suspicious SSL Certificate**:
    - The certificate's validity period spans from 2036-02-11 to 2046-02-08, which is unusually long and raises further suspicion about its legitimacy. Infact the certificate has been issued in 2036 which is 12 years from now, and expires in 22years from now

EVIDENCE:



---

2. The Server IP Address is Found in Threat Feeds:

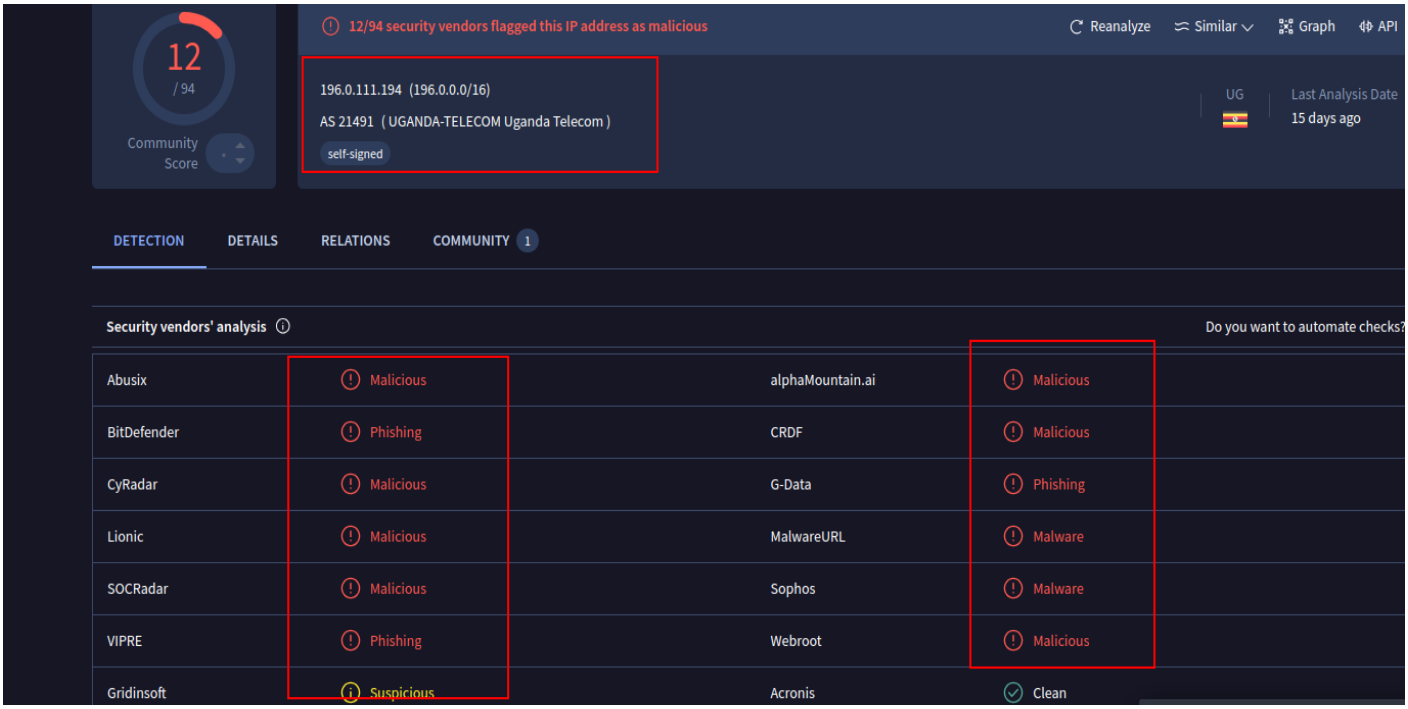
- **12 Security Vendors Flagged the IP as Malicious:**
    - This indicates that 12 Security solution vendors identified this IP as a security risk, warranting immediate action.

Threat Classifications by Cyber Security Vendors:

- **Phishing:**
    - Detected by **BitDefender**, **G-Data**, and **VIPRE**.
    - Suggests the IP is being used to host phishing websites or for phishing campaigns via email.

- **Malware Distribution:**
  - Detected by **Sophos**, **MalwareURL**, and others.
  - Indicates the IP is potentially hosting malicious payloads or serving as part of a malware distribution network.
- **General Malicious Activity:**
  - Detected by **Abusix**, **alphaMountain.ai**, **CyRadar**, **Lionic**, **SOCRadar**, and **Webroot**.
  - Includes use in DDoS attacks, botnets, or as command-and-control (C2) infrastructure.

EVIDENCE:



---

3. Malicious cyber Groups and Activities Associated with the Server:

- **Arkei Stealer:**
  - **Arkei Stealer** is a malware family known for stealing credentials and sensitive data. Its presence indicates the IP is used as part of campaigns targeting user credentials or sensitive information. this malicious software, is commonly classified as an info-stealer, that is designed to harvest sensitive information from infected systems. It primarily targets personal and financial data, such as login credentials, credit card information, cryptocurrency wallet details, browser-stored passwords, cookies, and other valuable user information. Arkei Stealer typically spreads through phishing

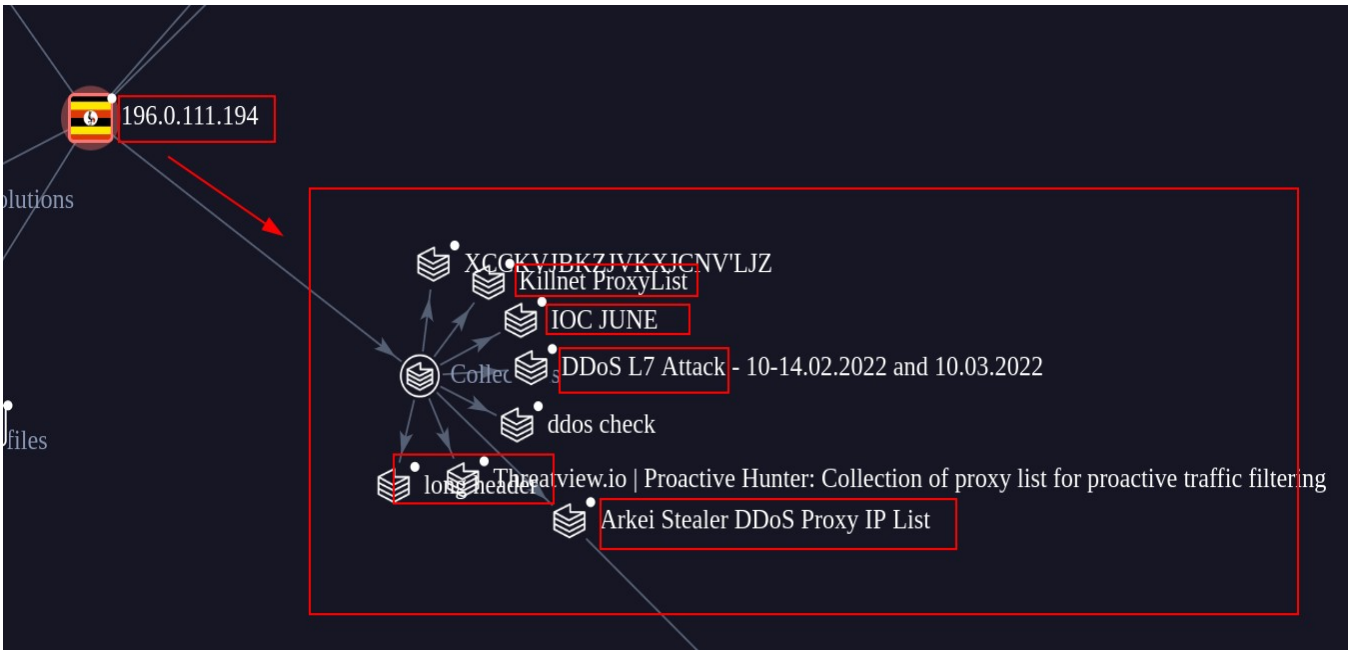
campaigns, malicious attachments, fake software downloads, or cracked software, exploiting vulnerabilities to infiltrate systems.

- **Killnet:**
    - Associated with the Killnet threat actor group, which is notorious for politically motivated cyberattacks, including high-profile Distributed Denial of Services (DDoS) attacks operations. Killnet is a pro-Russian hacking group known for conducting cyberattacks, primarily Distributed Denial of Service (DDoS) attacks, against organizations and governments that it perceives as opposing Russia's geopolitical interests. The group emerged prominently in early 2022 during the Russia-Ukraine conflict, targeting entities in NATO countries, including government websites, financial institutions, and healthcare system.

- **DDoS Proxy IP List:**
    - The IP has been listed as part of a proxy infrastructure used in Distributed Denial-of-Service attacks, emphasizing its role in amplifying or initiating such attacks.
- **Long Header:**
    - Refers to the use of excessively long HTTP headers than the usual standard , often employed by attackers to evade detection or exploit vulnerabilities. These headers can be used for obfuscation, making it harder for security systems to analyze requests, or to target poorly configured web servers with buffer overflow or denial-of-service attacks. Long headers may also serve as a vehicle for delivering malicious payloads, such as SQL injection or cross-site scripting (XSS), highlighting their role in a variety of exploit techniques."

- **IOC June:**
    - The IP is listed as an Indicator of Compromise (IOC) in reports from June, corroborating its use in malicious campaigns around that period.
- **DDoS LT Attack:**
    - Refers to participation in a prolonged Distributed Denial-of-Service (DDoS) attack campaign, where the target is overwhelmed with a continuous stream of traffic to disrupt its operations. Such long-term attacks are often carried out by botnets, networks of compromised devices under the control of attackers. The extended duration of the attack suggests a coordinated effort to exhaust the target's resources over time, making recovery and mitigation more challenging. This type of attack can severely impact the availability of critical services and infrastructure."

EVIDENCE:
(Next page)

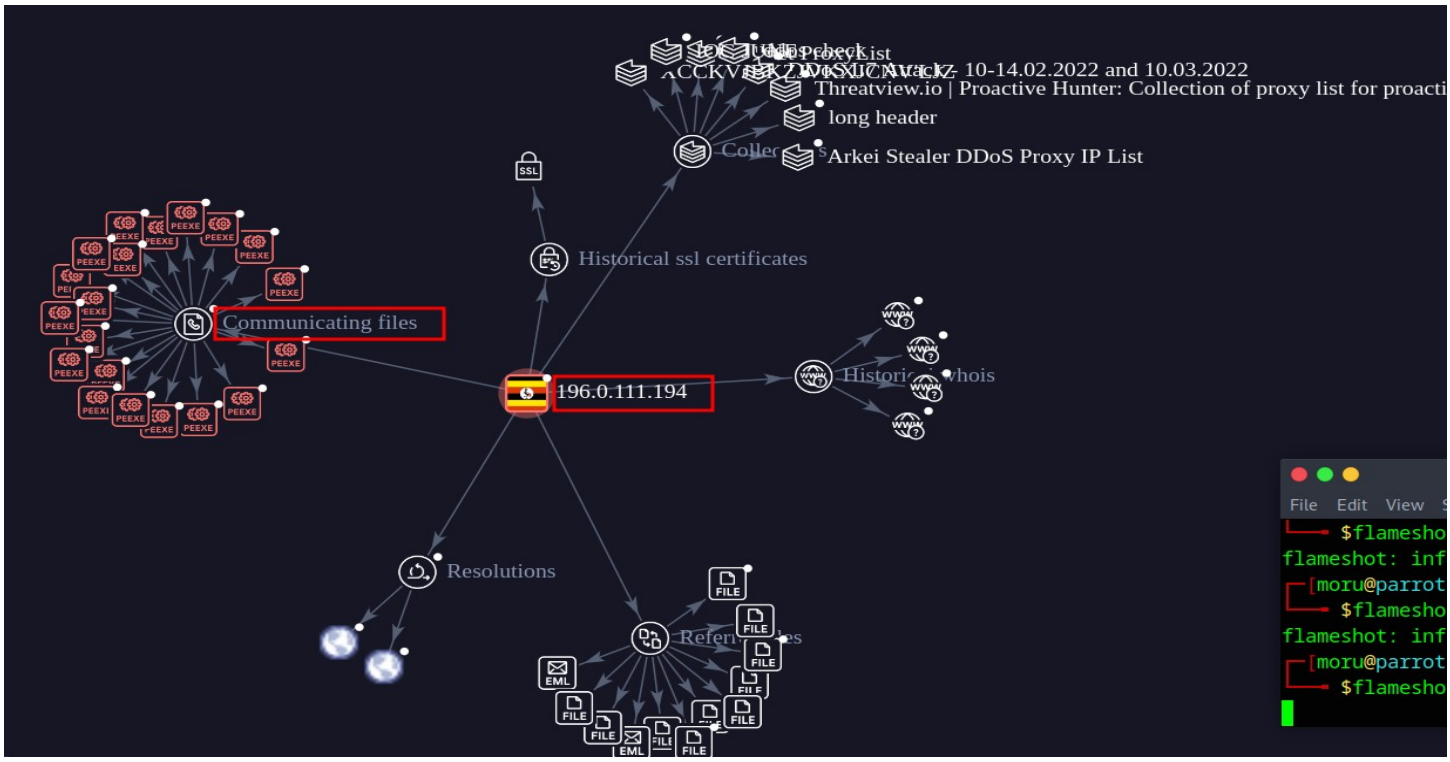


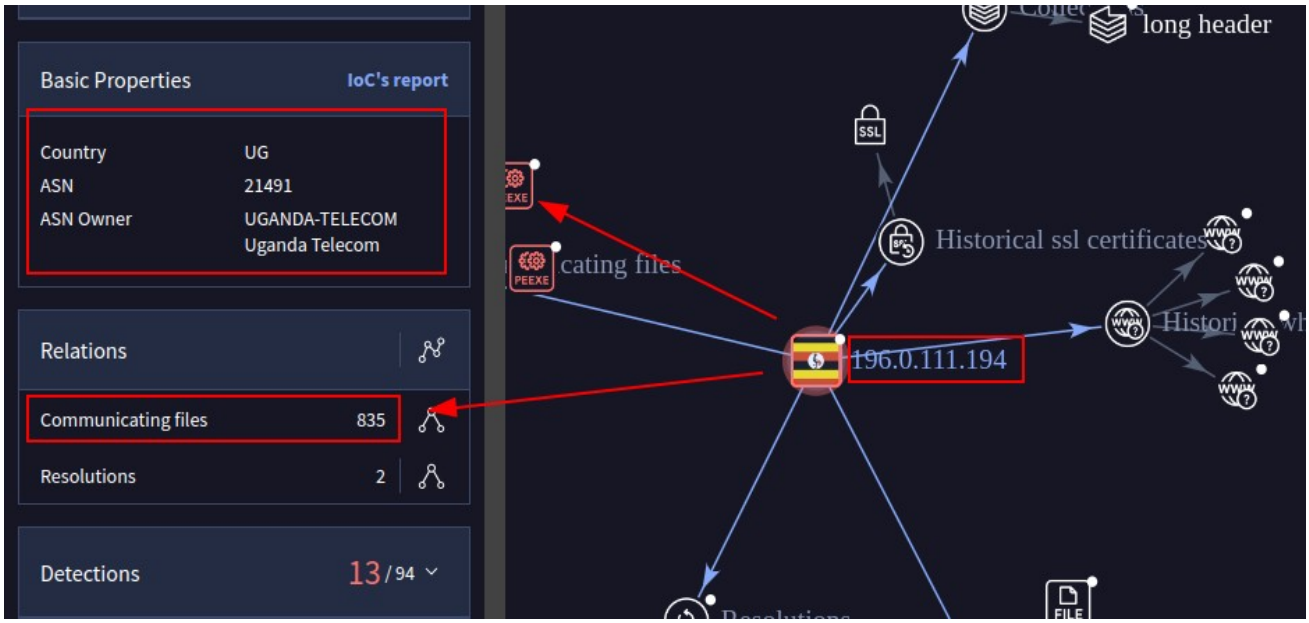
---

4. Numbers of Malicious Files Communicating to the Server directly:

- **835 Files are Communicating with the IP:**
  - Indicates extensive activity, potentially stemming from infected devices, malicious scripts, or automated processes leveraging the IP for command-and-control, malware distribution, or data exfiltration.

EVIDENCE:



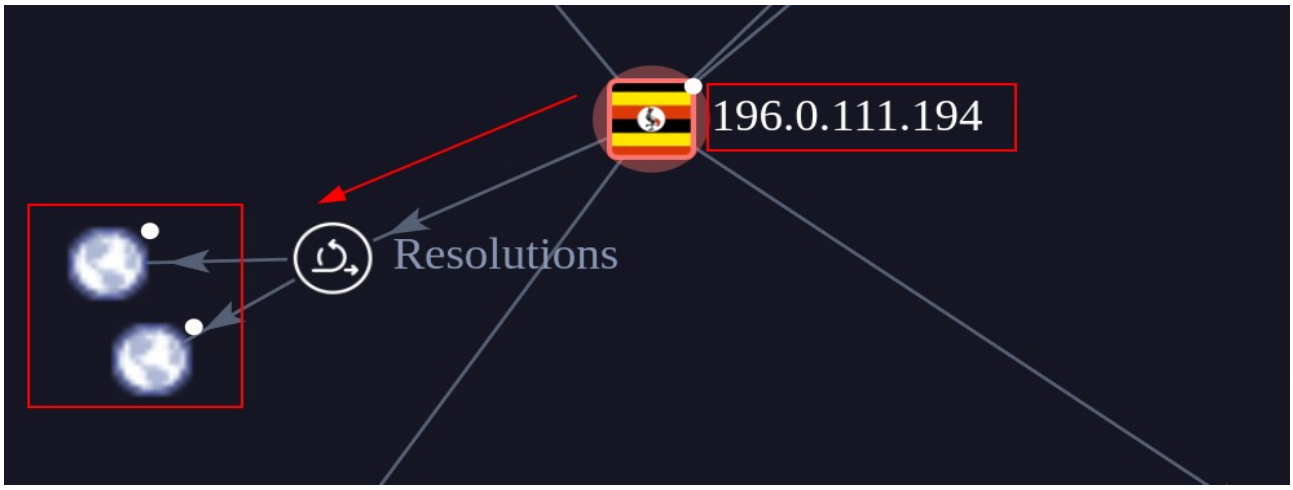


---

5. DNS Activity:

- **2 DNS Resolutions:**
  - Suggests active DNS queries resolving to this IP, likely for malicious domain resolution or C2 communication.

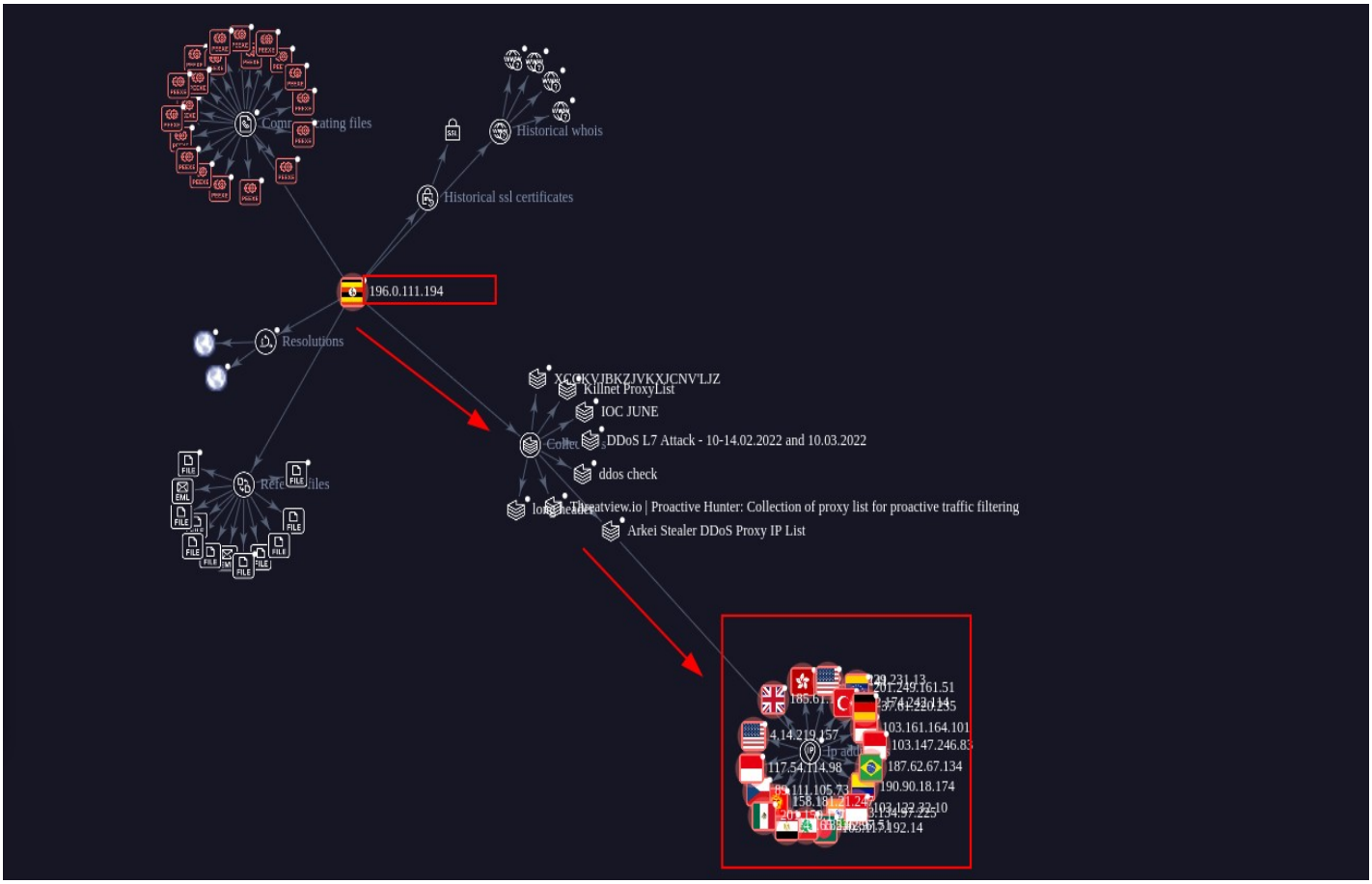
EVIDENCE:



6.Affected Countries By the Server’s Activities:

The server has been linked to distributing attacks targeting various countries through activities such as phishing campaigns, malware distribution, Distributed Denial of Service (DDoS) attacks, command-and-control operations, data exfiltration, and botnet activities. These malicious operations have, in one way or another, **impacted a total of 20 countries**, to mention but a few includes: **United States of America, United Kingdom, Singapore, Poland, Turkey, Ukraine, Germany, Venezuela, Brazil, Mexico, Spain, India, etc...** The widespread impact indicates the global reach of the server's activities and the need for coordinated efforts to mitigate these threats.

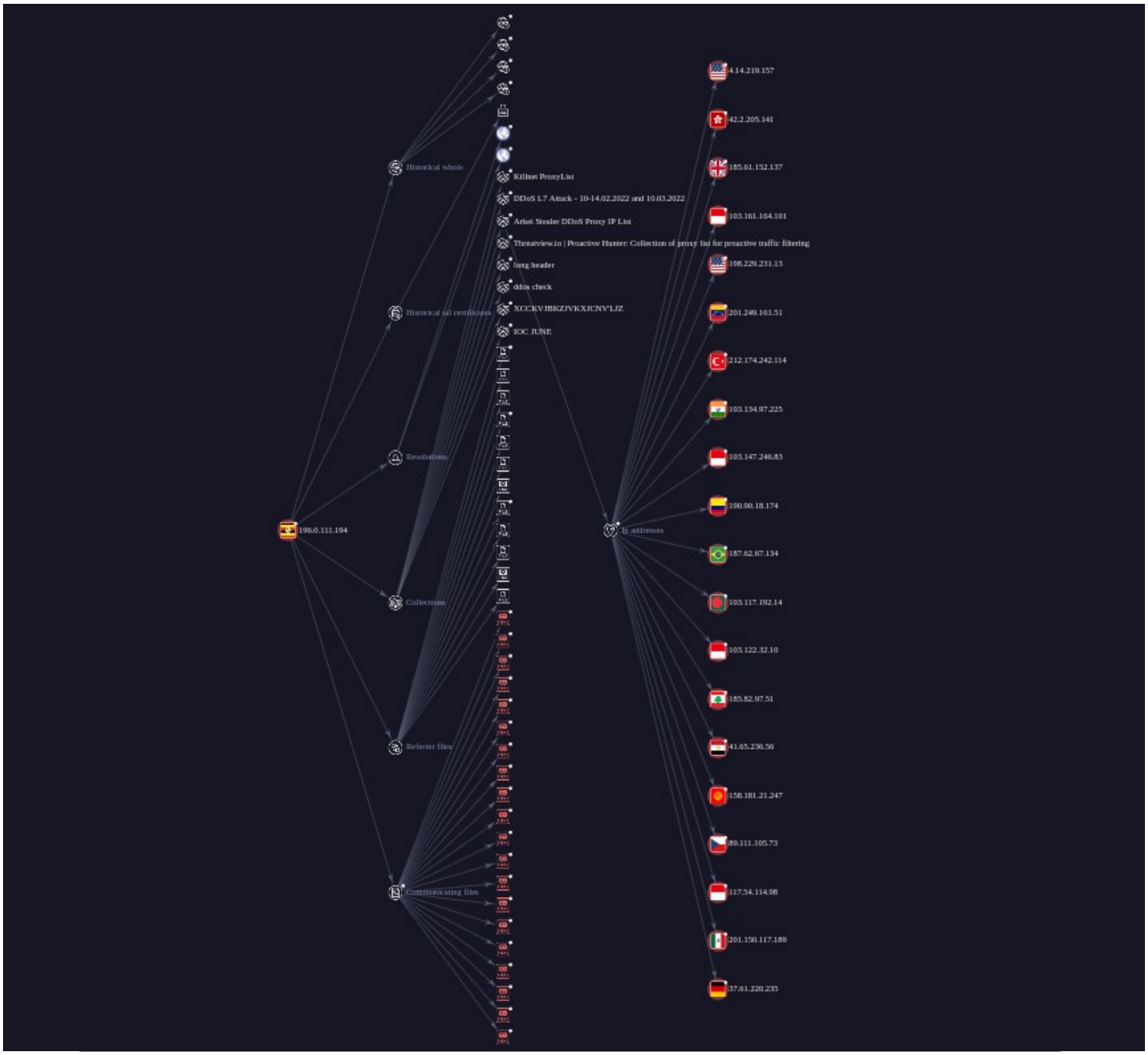
EVIDENCE:



6. Visualized Attack Path From the Server

This tree graph below provides a detailed visualization of the attack path patterns originating from the malicious server in question and demonstrates how these paths are being exploited. Each branch of the graph represents a specific action or step taken by the attacker, offering a clear depiction of how the malicious activities propagated from it. By highlighting these paths, the graph helps to uncover the techniques, tactics, and procedures (TTPs) employed by the attacker, allowing for a better understanding of the server's role in executing and distributing these activities. This visualization serves as a crucial tool for identifying vulnerabilities and understanding the overall structure of the attack.

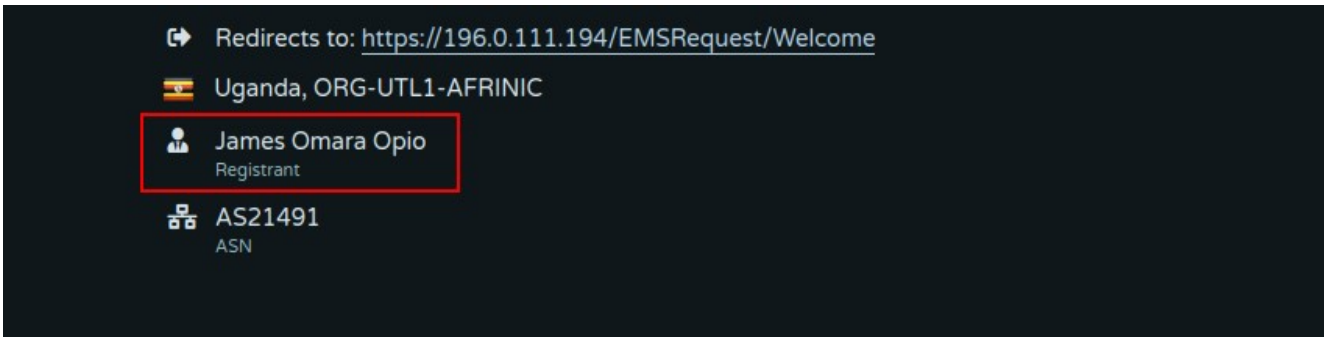
Evidence:



7. Server Ownership Details:

The server in question is registered in Uganda, specifically located in Kampala. It is associated with the organization **ORG-UTL1-AFRINIC** (Uganda Telecom Limited). The registered owner of the server is **James Omara Opio**, who appears to hold responsibility for its operation and management. The geolocation and ownership information indicate that the server is under the jurisdiction of Uganda, and any activities associated with the server may be subject to local laws and regulations. Further investigation into the owner's involvement or potential misuse of the server may be necessary to determine their role in any malicious activities linked to the server**.**

EVIDENCE:



---

8. Implications of Findings

1. **Phishing Risk:**
    - The association with phishing activities poses a significant threat to users, potentially leading to credential theft and further attacks.
2. **Malware Distribution:**
    - The IP's role in hosting or distributing malware increases the risk of infection for any systems communicating with it.
3. **Botnet Activity:**
    - Inclusion in DDoS proxy lists suggests the IP is part of a larger botnet infrastructure, capable of launching large-scale attacks.
4. **Association with Killnet:**
    - Links to Killnet heighten the risk due to their known expertise in targeted DDoS campaigns and disruptive activities.

Recommendations

Immediate Actions:

1. **Blocklist the IP:**
    - Add `196.0.111.194` to firewall and IDS/IPS blocklists to prevent communication.
2. **Conduct Network Analysis:**
    - Inspect network traffic for any connections to this IP.
    - Review logs from DNS servers, proxies, and firewalls for traces of this IP.
3. **Isolate Potentially Compromised Systems:**
    - Identify and quarantine any systems that may have communicated with this IP.

Forensic Investigation:

1. **Analyze Communicating Files:**
    - Investigate the 834 files flagged as communicating with this IP.
    - Cross-reference file hashes with malware databases such as VirusTotal or Hybrid Analysis.
2. **Inspect DNS Queries:**
    - Look for patterns in DNS resolution that could indicate further malicious domains.

Importance of Timely Action

Cybersecurity threats are a significant risk for any organization. Addressing these findings promptly will help protect your organization’s sensitive data, maintain your reputation, and prevent potential service disruptions. Failing to act could result in unauthorized access, financial losses, or legal implications due to data breaches.

Disclosure Intent

I am committed to responsible disclosure and have not shared this information with any third parties. Thank you for your attention to this matter, and I hope it helps improve your system’s security. This notification is provided in good faith and with no expectation of compensation. my intention is solely to support people, organizations, society, etc ... regarding their security posture.

Conclusion

The IP `196.0.111.194` is a high-risk asset involved in a range of malicious activities, including phishing, malware distribution, and botnet operations. Immediate action is necessary to mitigate risks, including isolating compromised systems, blocking the IP, and engaging relevant stakeholders for remediation.

Thank you for your attention to this matter.

Sincerely,

William Moru
Cybersecurity Engineer | Certified Ethical Hacker | Senior Software Tester (app security)

EMAIL: moruwilliam7@gmail.com
